

今月のフロントエンド

フロントエンド エンジニア集会 2026 年 5 月

"今月のフロントエンド" とは

今月あったフロントエンドのニュースを, 以下のフォーマットで紹介します.

- ニュースがあった技術について, その名前かキーワード
- その技術に関する解説 (3 行目安)
- 何があったかを解説

取り上げないもの

- 特定フレームワークに関するバージョンアップ (例外あり)
- AI 単品のニュース

ECMAScript 2026

2026/03/26



"ECMAScript" とは

- JavaScript のコア仕様を定める標準規格
- TC39 が策定し, 毎年 6 月頃に最終版が承認される年次リリース
- 各ブラウザや Node.js のランタイムはこの仕様を実装する

ECMAScript 2026 のニュース

ES2026 RC が公開, Temporal が Stage 4 入り

- **Temporal API** が Stage 4 → ES2026 仕様に正式採用
 - `Date` の代替, イミュータブル, タイムゾーン / 暦をネイティブサポート
- `JSON.parse` の **source text アクセス** (BigInt 安全な数値復元)
- `Iterator.concat()` ほか, **イテレータ系メソッドの拡充**
- `Array.fromAsync` も標準入り

Google Chrome

2026/05/05



"Google Chrome" とは

- Google が開発する Web ブラウザ, デスクトップでは圧倒的シェア
- レンダリングエンジンは Blink, JS エン진은 V8
- ブラウザベンダーの中で **新規 Web API の提案 / 実装をもっとも積極的に推進**

Chrome のニュース

Chrome 148 で Prompt API が安定版に

- ブラウザに同梱された **Gemini Nano** を JavaScript から直接呼べる API
- ローカル推論, API キー不要, テキスト / 画像 / 音声入力に対応
- ユースケース: 画像キャプション生成, オフライン書き起こし, 構造化抽出など

"標準" としての問題

Mozilla / Apple WebKit / Microsoft / W3C TAG が反対する中で単独シッブ

- Chrome エンジニア本人すら懸念を表明
- Mozilla の Jake Archibald 氏: "A sad time for web standards."
- 約 **4.27 GB のモデル** がユーザー同意なくダウンロードされていた件も発覚
- "Web 標準" のあり方そのものが問われる事例に

Node.js

2026/04/22



"Node.js" とは

- サーバーサイドで JavaScript を実行するランタイム
- フロントエンドのビルドツール / 開発サーバーの基盤としても必須
- 先月リリースサイクルの刷新が発表され, **年 1 回 / 全 LTS 化** の流れへ

Node.js のニュース

Node.js 26 がリリース

- 現行リリースモデル下での最後のメジャーリリース
- 2026/10/28 に Active LTS 入り予定 (EOL は 2029/04)
- 次の **Node.js 27 (2027/04 予定) から新モデル** に移行
 - 全リリース LTS 化 / 年 1 回リリース / バージョン番号は西暦下二桁

今月のインシデント

フロントエンド エンジニア集会 2026 年 5 月

"今月のインシデント" とは

今月あったフロントエンド周辺のインシデントを, 以下のフォーマットで紹介します.

- インシデントの起きた技術について, その名前がキーワード
- その技術に関する解説 (3 行目安)
- 何が起きたかを解説

取り上げないもの

- フロントエンドと無関係なエコシステム単独の事案 (PyPI のみ, Go のみ など)
- 個別 CVE レベルの脆弱性の発見・修正
- SaaS / クラウド事業者単体への攻撃 (npm を経由しないもの)

axios

2026/03/31

npm

"axios" とは

- ブラウザ / Node.js で動く HTTP クライアントライブラリ
- Promise ベースの直感的な API で, fetch 以前から広く使われてきた定番
- npm の週間ダウンロード数は **約 1 億回** という巨大パッケージ

axios のインシデント

メンテナアカウントが乗っ取られ, 悪意のあるバージョンが公開

- 3/31 に `1.14.1` / `0.30.4` の 2 バージョンが npm 上に出現
- `plain-crypto-js@4.2.1` を依存に注入し, **RAT (Remote Access Trojan)** を配布
- macOS / Windows / Linux いずれにも対応する仕掛け
- 公開からおよそ **3 時間で削除** されたが影響範囲は甚大

何が起きたのか

- メンテナ個人が攻撃対象となり, **PC への侵入を許してしまった**
- そこから npm の認証情報を奪われ, アカウントの登録メールアドレスも変更された
- 結果として攻撃者が **正規メンテナとして 悪意のあるバージョンを公開**

1 人のメンテナの PC が落ちると, 世界中の CI が壊れる

TanStack

2026/05/11



"TanStack" とは

- TanStack Query (旧 React Query), Router, Tableなどを擁する人気ライブラリ群
- フレームワーク非依存を志向し, React / Vue / Solid / Svelte など幅広くサポート
- Tanner Linsley 氏が主導, モダンフロントエンドの "事実上の標準" のひとつ

TanStack のインシデント

42 個の `@tanstack/*` パッケージに悪意のあるバージョンが公開

- 5/11 19:20～19:26 UTC のわずか **6 分間** で 84 バージョンが一斉公開
- `@mistralai/*`, `@squawk/*`, OpenSearch, Guardrails AI, UiPath などとも巻き込み
- 最終的に **170+ パッケージ / 400+ 悪意バージョン** に拡大
- 外部研究者により 20～26 分で検知 → 全バージョン deprecate, npm 側で tarball 削除

攻撃手法: Mini Shai-Hulud

- GitHub Actions の `pull_request_target` ("Pwn Request") パターンを悪用
- フォークとベースの信頼境界をまたぐ Actions キャッシュポイズニング
- ランナープロセスのメモリから **OIDC トークン**を抜き取り, npm 連携を奪取
- パスワードや token を盗むのではなく, **CI の信頼関係そのもの** を悪用

"ワーム" としての怖さ

- 盗んだ npm トークン / GitHub PAT で 被害者が書き込み権を持つ別パッケージにも伝播
- npm / PyPI / Composer を 横断 して自己複製
- 開発者マシンには `gh-token-monitor` を常駐, 60 秒ごとに GitHub をポーリング
- token 失効 (40X) を検知すると `rm -rf ~/` を試みる デッドマンスイッチ付き

史上初の "正規署名された" 悪意パッケージ

- 侵害版は **SLSA Build Level 3 の provenance attestation** を正しく持っていた
- 「ビルドの出所が検証できる」仕組みを潜り抜けた最初の事例
- "署名されているから安全" は崩れた

Shai-Hulud の系譜

時期	名称	規模
2025/09	Shai-Hulud (初代)	数百パッケージ
2025/11	Shai-Hulud 2.0	796 パッケージ / 週 2,000 万 DL
2026/05	Mini Shai-Hulud	170+ パッケージ / 400+ バージョン

- 名前は『デューン』に登場する砂漠の巨大ワーム
- 半年ごとに進化して舞い戻ってくる

その後

攻撃者が Mini Shai-Hulud のコードを GitHub に一般公開

- ライセンスは MIT, 誰でも自由に再利用可能
- 同時に "最大のインシデントを起こした者に賞金 \$1,000" のキャンペーンを開催
- 攻撃手段が コモディティ化 し, 同じ手口の亜種が無数に飛んでくる前提に

我々はどう守るか

- `package-lock.json` / `yarn.lock` のコミットは前提として
- 依存追加時には **新しいバージョンを即座に取り込まない** (数日寝かせる)
- CI の GitHub Actions では `pull_request_target` を **原則禁止**
- `npm install` 時の **postinstall / prepare スクリプトを無効化** する
選択肢 (`--ignore-scripts`)
- 開発機と本番環境のクレデンシャルを **物理的に分離**

おわり